

R15

HTB · STARTING POINT

HTB Starting Point — Appointment

Programación para Ciberseguridad · Fase II · AD2026

HTTP es el protocolo de la web. Un servidor web expone una interfaz de login que, si no valida correctamente las entradas del usuario, puede ser bypassada con una inyección SQL básica. Esta máquina introduce la enumeración web desde la terminal con **nmap** y **curl** — herramientas nativas de Bash.

Objetivo: Enumerar el servicio HTTP de la máquina, identificar el panel de login y obtener acceso usando una inyección SQL básica para recuperar la flag.

Acceso a la plataforma

1. Inicia sesión en <https://app.hackthebox.com>, conecta la VPN de HTB.
2. Ve a Starting Point → Tier 1 → Appointment e inicia la máquina.
3. Anota la IP asignada.

Pistas de enfoque

Escanea con **nmap -sV <IP>** para identificar el servicio HTTP. Visita la dirección IP en el navegador o usa **curl <IP>** para ver la página. Una vez que encuentres el formulario de login, prueba el clásico payload SQL en el campo de usuario: **admin'#** (esto comenta el resto de la consulta SQL). La contraseña puede ser cualquier texto.

Recuerda: La inyección SQL es una técnica ofensiva. Practicarla aquí, en un laboratorio controlado de HTB, es exactamente para lo que fue diseñada esta máquina. Usar estas técnicas fuera de este entorno, sin autorización explícita por escrito, constituye acceso no autorizado a sistemas informáticos.

Evidencias requeridas

- Screenshot del escaneo de **nmap** con el servicio HTTP identificado.
- Screenshot del panel de login y del payload SQL utilizado.
- Screenshot de la flag obtenida tras el acceso exitoso.

Preguntas de reflexión

1. El payload **admin'#** funciona porque la comilla cierra prematuramente la cadena SQL y el **#** comenta el resto. ¿Qué debería haber hecho el desarrollador del formulario para prevenir esto desde el principio?
2. **curl** puede enviar formularios desde la terminal con la bandera **-d**. ¿Qué ventaja tiene usar **curl** en lugar del navegador para probar vulnerabilidades web en un entorno controlado?
3. Esta es tu primera máquina de Tier 1. Compara la dificultad con las de Tier 0 (Meow, Fawn, Dancing, Redeemer). ¿Qué habilidad adicional necesitaste que no usaste en ninguna de las anteriores?